

“代码即规则”之后——DAO、Solana 与 Ronin 的安全和治理边界

第一种风险：代码本身有漏洞

2016 年 The DAO 遭遇攻击。Ethereum Foundation 当时说明，攻击利用递归调用方式反复触发分拆函数，导致资金被转移。后来 Ethereum 社区通过硬分叉处理后果，也由此形成 Ethereum 与 Ethereum Classic 两条路径。这个事件说明：智能合约“自动执行”并不等于合约逻辑永远正确。^[1,2,3]

第二种风险：网络可能停止服务

2021 年 9 月 14 日，Solana 官方报告称网络离线约 17 小时，未发生资金损失，随后由社区恢复运行。高吞吐区块链同样需要面对拥堵、验证者协同和故障恢复。共识机制解决的是节点如何达成一致，却不意味着网络永不停止。^[4]

第三种风险：跨链桥的信任集中

Ronin 官方在桥恢复公告中确认，2022 年 3 月攻击导致 173,600 ETH 和 25.5M USDC 被盗。此后新的桥设计加入更严格治理和熔断机制。Ronin 随后也公开反思“真正分布式网络”的重要性。^[5,6]

三个事件的共同问题

DAO、Solana 和 Ronin 分别对应合约代码、网络可用性和跨链治理风险。它们说明“链上不可易改”只是安全的一部分。一完整系要考代、点分布、限、常暂停、升级和恢复。^[3,6]

治理是技术系统的一部分

DAO 事件之后是否回滚、Solana 故障如何者、Ronin 桥如何重新设计权限阈值，都需要人和组织做出决定。因此，区块链并没有消灭治理，而是把治理规则更明确地嵌入技术与社区机制之中。^[2,4,6]

DAO 事件把“代码错误”变成治理危机

The DAO 并不是普通网站漏洞。资金按照智能合约代码执行，攻击者利用递归调用逻辑把资产转出时，链本身仍然按照既定规则正确记录交易。问题出在合约规则本身存在漏洞。^[1,2,3]

随后社区是否通过硬分叉改变历史状态，引发了“代码执行结果是否应被人为干预”的争论。最终形成不同链的选择说明，即使去中心化网络也需要面对价值判断和集体决策。安全事件因此很快从程序问题升级为治理问题。^[1,2,3]

Solana 故障说明可用性也是安全的一部分

区块链常用“不可篡改”描述数据安全，但用户还需要系统持续可用。Solana 2021 年故障持续约 17 小时，官方说明网络在验证者协调后恢复。期间没有资金被直接盗走，但无法正常处理交易本身就是严重服务风险。^[4]

高吞吐系统需要处理流量激增、资源消耗和验证者协同。共识协议能让节点在正常条件下达成一致，却不能消除软件缺陷、拥堵和运维恢复问题。^[4]

Ronin 把跨链桥的权限风险暴露出来

跨链桥需要在不同网络之间确认资产锁定和释放，往往依赖一组验证者或密钥。如果控制权过度集中，攻击者只要取得足够签名权限，就可能绕过正常用户路径。Ronin 公开确认 2022 年攻击造成大量资产损失，此后重新设计验证与熔断机制。^[5,6]

这个事件说明所谓“去中心化应用”中仍可能存在高度集中的关键组件。评估系统安全时，不能只看底层公链节点数量，还要追踪跨链桥、管理员密钥、预言机和升级权限。^[5,6]

三起事件对应三种不同的失效模式

DAO 主要是合约逻辑失效，Solana 主要是网络可用性失效，Ronin 主要是跨链验证和权限治理失效。三者都发生在区块链生态中，却不能用一个“51%攻击”概念解释。^[3,4,6]

这提示安全设计必须分层：合约要审计和限制权限，网络要具备监控和恢复机制，跨链桥要降低密钥集中并设置限额、熔断和应急暂停。治理机制则要说明谁可以触发这些措施。^[3,4,6]

“不能改”与“出了问题怎么办”必须同时设计

不可篡改强调的是正常账本历史不应被单方随意重写，但任何真实系统都可能发生漏洞和事故。如果制度完全没有升级、暂停和修复机制，一次错误就可能永久扩大。^[2,3,6]

成熟区块链治理因此需要同时约束正常权限和异常权限：平时谁都不能随意改，出现重大事件时又要有透明、受约束、可审计的应急流程。^[2,3,6]

业务关系

DAO、Solana与Ronin安全治理：主要参与主体

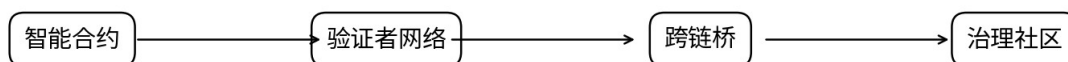


图 1 主要参与主体与业务关系（根据公开资料整理）

关键事件

DAO、Solana与Ronin安全治理：关键事件/流程

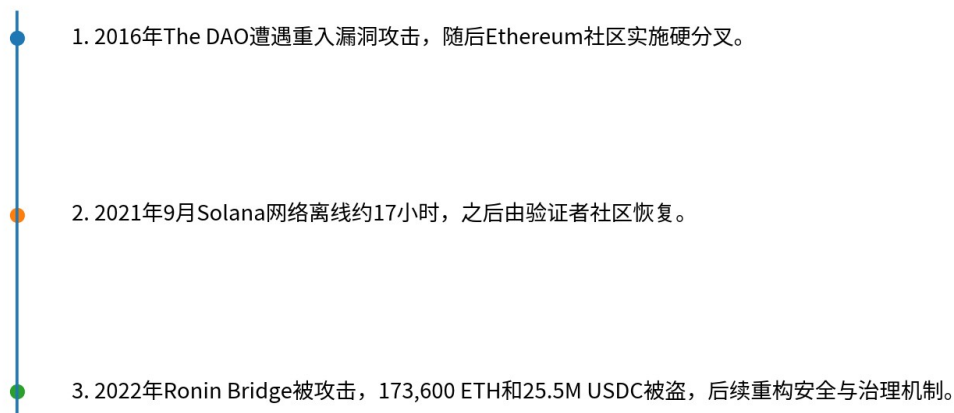


图 2 关键事件与业务演进（根据公开资料整理）

问题仍在

当智能合约、共识网络或跨链桥出现问题时，“不可篡改”为什么仍不能等同于“绝对安全”？

参考资料

- [1] Ethereum Foundation Blog. CRITICAL UPDATE Re: DAO Vulnerability[EB/OL].
<https://blog.ethereum.org/2016/06/17/critical-update-re-dao-vulnerability>
- [2] ethereum.org. Ethereum Governance[EB/OL]. <https://ethereum.org/governance/>
- [3] ethereum.org. Smart contract security[EB/OL].
<https://ethereum.org/developers/docs/smart-contracts/security/>
- [4] Solana. 9-14 Network Outage Initial Overview[EB/OL]. <https://solana.com/news/9-14-network-outage-initial-overview>
- [5] Ronin. The Ronin Bridge Is Open[EB/OL]. <https://blog.roninchain.com/p/the-ronin-bridge-is-open->
- [6] Ronin. Securing Ronin[EB/OL]. <https://roninchain.com/blog/posts/securing-ronin-6513cc78a5edc1001b03c365>